VF-1D-A-696 — Siber Risk Kaydı

Analizin kapsamı

LAB 3'te geliştirilen üç senaryo; fiziksel tehlike, emniyet fonksiyonu ve azaltma önerileriyle eşleştirilmiştir. Senaryoların tam anlatımı LAB 3 belgesindedir.

L istismar edilebilirlik, S fiziksel şiddet, E saldırı yolunun dışa açıklığıdır. Skor = L × S × E. Kritik: 18–27; yüksek: 9–17; orta: 4–8; düşük: 1–3. S=3 olanlar ayrıca S3 bayrağıyla izlenir. Bu eğitim ölçeği, ISO 12100 için sayısal risk yöntemi olarak kullanılmamıştır.

Öncelik tablosu

Risk	L	S	E	Skor	Öncelik
R02 — Olası uzak bakım	2	3	3	18	Kritik; S3
R01 — Operatör istasyonu	2	3	2	12	Yüksek; S3
R03 — Yerel servis	1	3	1	3	Düşük; S3

Puanlar LAB 3'te belirtilen erişim ve koruma varsayımlarına aittir. Gerçek mimarinin doğrulanması, senaryoyu veya puanlarını değiştirebilir.

R01 — Operatör istasyonunda yetkisiz değişiklik

Bağlantı: LAB 3, Senaryo 1 → T01 sıcak yüke erişim → SF1 güvenli erişim.

Temel varsayım: Fabrika ağındaki operatör istasyonundan erişim izniyle ilişkili parametre yazılabiliyor; bağımsız koruma bu değişikliği engelleyemiyor.

Puan gerekçesi: L=2, kullanıcı erişimi ve yetersiz yetki sınırı gerekir. S=3, sıcak yüke erişim ağır yanığa yol açabilir. E=2, giriş fabrika ağından erişilebilirdir.

Azaltma önerisi: Operatör ve mühendislik yetkilerini ayırmak; SF1 yapılandırmasını proses hesabına kapatmak ve değişiklikleri kaydetmek.

Beklenen kanıt: Yetki matrisi, erişim yapılandırması, emniyet parametresi yazma sınırı ve değişiklik kayıtları.

İnceleyecek rol önerisi: OT kontrol ve emniyet sorumluları.

R02 — Olası uzak bakım yolunun kötüye kullanılması

Bağlantı: LAB 3, Senaryo 2 → T01 aşırı ısınma → SF2 aşırı sıcaklık koruması.

Temel varsayım: Sürekli açık dış bağlantı ve ele geçirilebilir bakım hesabı üzerinden koruma ayarlarına ulaşılabiliyor; bağımsız koruma da etkileniyor. Modele özel uzak erişim henüz doğrulanmadı.

Puan gerekçesi: L=2, bakım hesabının ele geçirilmesi gerekir. S=3, öngörülen koruma kaybı yangına ve ağır yaralanmaya ulaşabilir. E=3, varsayılan dış bağlantı sürekli açıktır.

Azaltma önerisi: Bağlantı varsa MFA, kişisel hesap, kontrollü ara erişim ve süreli izin kullanmak; SF2'nin bakım erişimiyle devre dışı bırakılamamasını sağlamak.

Beklenen kanıt: Bağlantı envanteri, izinli bakım hedefleri, kimlik doğrulama ayarları ve bağımsız koruma doğrulaması.

İnceleyecek rol önerisi: OT/IT erişim ve emniyet sorumluları.

R03 — Yerel mühendislik erişimine müdahale

Bağlantı: LAB 3, Senaryo 3 → T02 tehlikeli basınçta erişim → SF1 güvenli erişim.

Temel varsayım: Yapılandırma yalnız makine başında fiziksel bağlantıyla yapılabiliyor; servis bilgisayarı ve değişiklik kontrolleri aşılabiliyor. İkinci koruma zinciri kesemiyor.

Puan gerekçesi: L=1, birden çok kontrolün aşılması gerekir. S=3, basınç güvenli değilken erişim ağır yaralanma oluşturabilir. E=1, yapılandırma fiziksel bağlantı gerektirir.

Azaltma önerisi: Servis bilgisayarını ve fiziksel programlama erişimini korumak; emniyet değişikliklerini onay ve doğrulamaya bağlamak.

Beklenen kanıt: Servis erişim prosedürü, yapılandırma yedeği, onaylı değişiklik kayıtları ve kilitleme fonksiyonu doğrulaması.

İnceleyecek rol önerisi: Servis ve emniyet sorumluları.

Değerlendirme ve kapatma ölçütü

Üç kaydın durumu analiz aşamasındadır. Koruma önerilerinin uygulanması doğrulanmadığı için artık risk puanı verilmemiştir. S3 işaretli kayıtlar, önlem veya yazılı kabul kararı olmadan kapatılmaz. Rol önerileri görev ataması değildir.

Kaynaklar

• LAB 1 — SF1 ve SF2.

• LAB 2 — Önerilen bölgeler ve geçişler.

• LAB 3 — Senaryolar ve puan gerekçeleri.

• Fiziksel tehlike tablosu.

• Fatih Özkaynak, Threat & Risk Lab + Safety 4.0 Risk Matrix (LAB3.pdf): PDF s. 23–33 ve 35–37.

• NIST SP 800-82 Rev. 3 — OT Security.

Sonuç

Varsayımlara göre R02 en yüksek skoru alırken R03 düşük skora rağmen S3 olarak öncelikli incelemede kalmaktadır. Temel azaltma alanları erişim yetkileri, emniyet yapılandırmasının korunması ve değişiklik doğrulamasıdır.